מחלקת תקשוב · שבוע רשתות · דף הנחיה למדריך

Domain, אימות, הצפנה ותעודות

זהות מנוהלת ב-Windows, הצפנה סימטרית ואסימטרית, תעודות ו-TLS

55 דקות	17	שטח
משך מומלץ	שקופיות כולל שער	רמת המיקוד

מותאם לטכנאי שטח · סביבת Windows מנוהלת

לפני שמתחילים

שטח	17	55 דקות
רמת המיקוד	שקופיות כולל שער	משך מומלץ

מטרת השיעור

לחבר בין תשתית הרשת, זהות ואמון: כיצד התחנה מאתרת DC, מאמתת משתמש, בודקת תעודה ומקימה חיבור TLS.

תוצר נדרש

בסיום החניך יפריד בין אימות להרשאה ובין הצפנה סימטרית לאסימטרית, ויסביר תעודה, Cipher Suite ו-TLS Handshake ברמת אבחון.

הכנה מראש

- לוודא שהקהל מכיר DNS, כתובת ו-Gateway מהשיעור הקודם.
- להכין דוגמה להודעת תעודה או כניסה מוכרת ללא פרטים רגישים.
- לעבור מראש על רצף ה-TLS Handshake ולשמור את ההסבר ברמת זרימה ותקלות.

גבול ההעמקה

לא מנהלים Active Directory, GPO או CA. לא נכנסים למתמטיקה של הצפנה, לניתוח אלגוריתמים או לפרטי פרוטוקול Kerberos.

חלוקת זמן מוצעת

חלק	מה מעבירים	דקות
פתיחה	Domain כגבול זהות	5
AD, DNS והצטרפות	אובייקטים, איתור DC וחשבון מחשב	9
אימות והרשאה	Kerberos, כרטיסים וזמן	10
שני סוגי הצפנה	תפקיד אסימטרי מול סימטרי	8
תעודות ומשא ומתן	שרשרת אמון ו-Cipher Suite	10
TLS Handshake	רצף וארבע משפחות תקלה	10
סגירה	שרשרת התלות	3

פתיחה מומלצת

כיצד שעון שגוי יכול לגרום לכניסה להיכשל גם כשהסיסמה נכונה והרשת זמינה?

Domain מחבר זהויות ומדיניות; DNS מאפשר לתחנה לאתר אותו

Active Directory מחזיק משתמשים, מחשבים, קבוצות ומדיניות. Domain Controller מספק שירותי זהות, ו-DNS מאתר אותו. Domain Join יוצר חשבון מחשב וערוץ מאובטח, לא רק שינוי שם.

ישות	תפקיד ב-Domain
Domain Controller	DNS · זהות · מדיניות
משתמש	חשבון Domain
תחנה	חשבון מחשב
קבוצה	הרשאות
שרת	שירות מוגן

Domain הוא גבול זהות ואמון, לא Subnet ולא VLAN.

לא גבול רשת

הגבול הוא ניהולי ואמוני, לא Subnet או VLAN. DNS ציבורי יכול לאפשר גלישה ועדיין להפיל Domain.

רצף

DNS מתאים ← איתור DC ← חשבון מחשב ← ערוץ מאובטח ← קבלת מדיניות.

מה הטכנאי בפועל בודק

הטכנאי אינו מתכנן מבנה ארגוני או מנהל הרשאות; עליו לזהות מהו אובייקט מחשב, ומדוע מחיקתו או חוסר התאמה פוגעים בתחנה. DNS שגוי הוא אחת הסיבות המרכזיות לכך שכתובת ה-IP עובדת אך הכניסה ל-Domain נכשלת.

זהות מאומתת עדיין אינה הבטחה לגישה

אימות עונה "מי אתה"; הרשאה מחליטה מה מותר. Kerberos משתמש בכרטיסים המוגבלים בזמן. פער שעון משמעותי גורם לדחייה, ו-Group Policy יכולה לשנות שירותים, חומת אש, תעודות והרשאות.

שלב	תפקיד
DNS	איתור DC
זמן	תוקף כרטיס
Kerberos	אימות
הרשאה	קבוצות

DNS וזמן קודמים לאימות; תעודה ושרשרת אמון קודמות ל-TLS.

התעודה כבר בתמונה

Certificate: שם · תוקף · מנפיק · שרשרת. TLS מתחיל באימות השרת ורק אחר כך בהצפנת התעבורה.

טעות אבחון נפוצה

אל תבלבלו בין אימות להרשאה בזמן אבחון: תקלה בהרשאה, כמו משתמש שלא רואה תיקייה משותפת, אינה בהכרח תקלה בסיסמה או בקשר ל-DC. גם ב-Group Policy הטכנאי אינו מנהל GPO, אבל צריך לדעת לאסוף gpresult ולבדוק אם המדיניות התקבלה.

שאלת ביניים

משתמש נכנס לתחנה אך אינו פותח תיקייה: האם זו בהכרח בעיית סיסמה?

אסימטרית מקימה אמון ומפתחות; סימטרית מגינה על המידע

מפתח ציבורי ניתן להפצה והמפתח הפרטי נשאר אצל בעליו. במהלך ה-Handshake הצדדים מאמתים זהות וגוזרים סוד משותף; לאחר מכן אותו מפתח Session זמני משמש להצפנה סימטרית מהירה.

אסימטרית

מפתח Public להפצה, מפתח Private נשאר אצל הבעלים.

משמשים לזהות ולהסכמה על סוד משותף.

סימטרית

אותו מפתח Session לשני הצדדים.

מהיר לתעבורה, ולכן משמש להצפנת המידע עצמו.

ה-Handshake מקים אמון ומפתחות; המידע עובר בהצפנה סימטרית.

מלכודת ניסוח

אין לתאר את מפתח ה-Session כקובץ שנשלח לצד השני; שני הצדדים גוזרים אותו בלי לחשוף אותו ברשת.

שלושת היעדים

TLS נותן סודיות, שלמות ואימות זהות. הצפנה לבדה אינה מוכיחה שהגענו לשרת הנכון.

התעודה מוכיחה זהות; ה-Cipher Suite קובע כיצד תוגן התעבורה

הלקוח בודק שם, תוקף, מנפיק ושרשרת עד Root מהימן. במקביל הלקוח מציע אפשרויות, והשרת בוחר Cipher Suite ששניהם תומכים בו. ב-TLS 1.3 הבחירה מתארת את הצפנת התעבורה ואת ה-Hash.

רכיב	ערך	תפקיד
הצעת הלקוח	TLS_AES_128_GCM_SHA256 · TLS_AES_256_GCM_SHA384 · TLS_CHACHA20_POLY1305_SHA256	ClientHello מציע את האפשרויות הנתמכות
בחירת השרת	TLS_AES_128_GCM_SHA256	ה-Cipher Suite ששני הצדדים תומכים בו
הצפנה	AES_128_GCM	הצפנה סימטרית + שלמות
Hash	SHA256	גזירת מפתחות

ב-TLS 1.3, גרסה, Key Exchange וחתימה מוסכמים לצד ה-Cipher Suite.

גבול ההעמקה

אין צורך לזכור שמות אלגוריתמים. המטרה היא לזהות שכשל התאמה יכול להפיל את החיבור לפני שעובר מידע יישומי.

שרשרת האמון

אמון נבנה מהתעודה דרך מנפיקים עד Root המותקן מראש במאגר האמון של המכשיר. חוליה חסרה, כמו Intermediate שלא הותקן, או Root שאינו מהימן, שוברים את השרשרת.

רק אחרי Hello, תעודה, גזירת מפתחות ו-Finished עובר מידע

ClientHello ו-ServerHello מסכימים על פרמטרים ומחליפים חומר לגזירת מפתחות. השרת מציג תעודה ומוכיח בעלות על המפתח הפרטי; שני הצדדים גוזרים מפתחות Session ומאשרים Finished.

שלב	כיוון	מה עובר
1	מהלקוח	ClientHello: גרסה, Cipher Suites, key share
2	מהשרת	ServerHello: ההצעה שנבחרה, key share
3	מהשרת	Certificate, CertificateVerify
4	משותף	אימות וגזירת מפתחות Session, בלי לשלוח אותם ברשת
5	מהשרת	Finished
6	דו-כיווני	Application Data מוצפנת סימטרית

מינוח

SSL הוא שם ישן שנשאר בשפה; הפרוטוקול המודרני הוא TLS.

תקלת TLS נופלת כמעט תמיד לאחת מארבע משפחות: זמן, שם, שרשרת אמון, או משא ומתן.

משפחת תקלה	דוגמה אופיינית
זמן או תוקף	שעון או תאריך מערכת שגוי
שם לא תואם	הפנייה נעשית בשם שונה מזה שרשום בתעודה
שרשרת אמון חסרה	Intermediate או Root שאינם מותקנים או אינם מהימנים
חוסר התאמה במשא ומתן	גרסת TLS או Cipher Suite שאינם משותפים לשני הצדדים

מהלך המצגת ונקודות אימות

#	נושא ותמצית	#	נושא ותמצית
1	**שער.** זהות ו-TLS נשענים על תשתית	2	**Domain ו-DC.** גבול זהות ואמון
3	**אובייקטים.** משתמשים, מחשבים, קבוצות ומדיניות	4	**DNS של Domain.** איתור DC באמצעות רשומות
5	**Domain Join.** נוצר חשבון מחשב ואמון	6	**אימות והרשאה.** מי אתה מול מה מותר
7	**Kerberos.** כרטיס לשירות	8	**זמן.** פער שעון מפיל כרטיסים ותעודות
9	**Group Policy.** מדיניות יכולה לשנות התנהגות	10	**יעדי אבטחה.** סודיות, שלמות ואימות
11	**סימטרית ואסימטרית.** אמון ומפתחות מול תעבורה	12	**תעודה.** שם, מפתח, מנפיק ותוקף
13	**שרשרת אמון.** Root עד Server	14	**Cipher Suite.** הצעה ובחירה משותפת
15	**TLS Handshake.** Hello, תעודה, מפתחות ו-Finished	16	**תקלות TLS.** זמן, שם, אמון ומשא ומתן
17	**תלות מערכתית.** רשת, DNS, זמן, זהות ו-TLS		

מילון קצר למדריך

Domain	גבול ניהולי של זהות ואמון	**CA**	גורם שחותם על תעודה
Kerberos	אימות מבוסס כרטיסים	**Certificate**	קישור זהות למפתח ציבורי
אסימטרית	זוג מפתחות ציבורי ופרטי	**Handshake**	הסכמה ואימות לפני מידע יישומי
סימטרית	אותו מפתח זמני לשני הצדדים	**Cipher Suite**	שילוב הצפנה ו-Hash שנבחר

שאלת סיום

השרת נגיש ב-IP ובפורט אך TLS נכשל. אילו ארבע משפחות תבדוק לפני שתאשים את היישום?

טעות שאסור להשאיר

לא לומר שהתעודה מצפינה את כל התעבורה, שהמפתח הפרטי נשלח ברשת, או שאימות זהות שווה הרשאה למשאב.